

Etapa 1 e 2 — Criação do Cenário

VerdeOps Engenharia

1. Identificação da Empresa e Contexto

O cenário é baseado na VerdeOps Engenharia, uma startup do setor de construção civil sustentável fundada em 2021, com sede em Florianópolis. A empresa é especializada no desenvolvimento de edificações de baixo ou zero impacto ambiental — projetos residenciais e comerciais que integram automação predial, monitoramento de consumo energético em tempo real e materiais de baixo carbono.

Seu diferencial de mercado é o uso intensivo de tecnologia para atingir metas de sustentabilidade: sensores IoT instalados nas obras coletam dados de consumo de energia, emissão de CO₂, desperdício de materiais e qualidade do ar, todos processados por uma plataforma proprietária em Python (Django) que gera relatórios de conformidade ambiental enviados diretamente a certificadoras como LEED e AQUA-HQE.

2. Perfil do Time de Desenvolvimento

A equipe técnica é enxuta — 7 pessoas no total: 3 engenheiros de software, 2 analistas de dados, 1 DevOps e 1 coordenador técnico. O ambiente de desenvolvimento utiliza VS Code com Python e Django no backend, integrado a dashboards em React no frontend.

Dada a pressão por crescimento rápido e a escassez de mão de obra especializada em greentech, o time adotou assistentes de IA generativa como ferramenta central do fluxo de trabalho. A IA é utilizada para:

- Gerar pipelines de processamento de dados dos sensores IoT
- Escrever algoritmos de cálculo de pegada de carbono
- Produzir relatórios automatizados de conformidade ambiental
- Criar integrações com APIs externas de certificação

Tudo isso com mínima revisão humana posterior.

3. Vulnerabilidade Principal e Contexto do Problema

A vulnerabilidade central explorada é a dependência excessiva de IA sem revisão humana. A introdução dos assistentes de IA ocorreu de forma orgânica e sem qualquer política de Governança de TI que regulasse seu uso.

Com o time reduzido e prazos agressivos, criou-se uma cultura em que o output da IA é tratado como suficientemente confiável para ir direto à produção. Os engenheiros geram código para os cálculos de emissão de CO₂ com IA, revisam superficialmente e fazem o deploy — sem validação dos parâmetros utilizados, sem checagem de normas técnicas atualizadas (como os fatores de emissão do IPCC ou da ANEEL) e sem auditoria dos dados que alimentam os relatórios.

O problema se manifesta de forma silenciosa: os relatórios de conformidade ambiental são gerados com fórmulas incorretas ou desatualizadas produzidas pela IA. Os dados parecem coerentes, os dashboards funcionam e nenhum erro é sinalizado — mas os valores reportados às certificadoras estão errados.

Exemplos de falhas silenciosas

Fatores de conversão de kWh para kg de CO₂ baseados em dados de anos anteriores
Cálculos de reaproveitamento de água que ignoram perdas por evaporação
Índices de emissão de materiais calculados com normas técnicas desatualizadas

4. Impacto Esperado Caso Não Seja Tratada

Em uma empresa cujo produto central é a garantia de conformidade ambiental, relatórios gerados por IA sem revisão técnica representam um risco existencial. Os principais impactos incluem:

Perda de certificação

Uma certificação LEED ou AQUA-HQE obtida com dados incorretos pode ser revogada mediante auditoria, gerando perda imediata da credencial que diferencia a VerdeOps no mercado.

Litígios contratuais

Contratos com incorporadoras frequentemente preveem cláusulas de desempenho ambiental. Falhas nos índices reportados configuram inadimplência contratual e podem resultar em processos judiciais.

Passivo regulatório

Com o avanço da legislação brasileira sobre ESG e taxonomia verde (alinhada ao Acordo de Paris), dados ambientais incorretos submetidos a órgãos públicos ou usados para captação de green bonds configuram passivo legal crescente.

5. Stakeholders Envolvidos

Os principais stakeholders impactados pela vulnerabilidade são:

Stakeholder	Interesse principal	Tensão com o time
-------------	---------------------	-------------------

CEO / Coord. Técnico	Crescimento e captação de contratos; pressão por velocidade de entrega	Subestimam o risco técnico do uso irrestrito de IA
Engenheiros de software	Usuários diretos das ferramentas de IA; produtividade individual	Ausência de diretrizes sobre quando revisar o output gerado
Analistas de dados	Pipelines IoT com volumes crescentes de dados	Dependem de algoritmos de IA sem capacidade de auditoria manual
Certificadoras (LEED/AQUA)	Integridade dos relatórios de conformidade ambiental	Auditam dados que podem estar incorretos sem sinais visíveis
Incorporadoras / clientes	Conformidade ambiental verificável e rastreável	Prejuízo direto se índices reportados estiverem errados
BNDES · FINEP · CVM	Rastreabilidade de dados ambientais para fomento e green bonds	Exigem evidências auditáveis que a startup não consegue fornecer

Prompts utilizados:

Crie um cenário para um trabalho final de Governança de TI do curso de Sistemas de Informação, seguindo a mesma estrutura do exemplo da MedSys Solutions fornecido, mas com uma empresa original. A empresa deve ser uma startup (até 20 pessoas) do setor de construção civil sustentável, com foco em edificações de baixo ou zero impacto ambiental que integra tecnologia em sua metodologia. A vulnerabilidade central a ser explorada é a dependência excessiva de IA generativa sem revisão humana. O cenário deve cobrir obrigatoriamente: (1) identificação da empresa e contexto, (2) perfil do time de desenvolvimento, (3) vulnerabilidade principal e contexto do problema, (4) impacto esperado caso não seja tratada, e (5) stakeholders envolvidos.

Etapa 3 e 4 — Construção e Análise

Descrição do projeto – Simulação de Governança em IA Generativa

Este projeto tem como objetivo analisar o impacto da aplicação de **regras explícitas de governança (REGs)** no comportamento de modelos de IA generativa, comparando cenários com e sem restrições estruturadas. A proposta é avaliar como essas regras influenciam a qualidade, segurança e confiabilidade das respostas geradas, especialmente em tarefas relacionadas a desenvolvimento de software e validação de dados.

Metodologia

Foram utilizados dois modelos de IA generativa (ChatGPT e Claude), aplicados em um fluxo de testes com dois cenários:

- **Cenário A – Sem governança:**
As respostas são geradas com base apenas no prompt inicial, sem imposição de regras de validação ou restrições adicionais.
- **Cenário B – Com governança:**
As respostas são condicionadas a um conjunto de regras explícitas (REGs),

aplicadas diretamente no prompt, com foco em segurança, validação de dados e rastreabilidade de decisões.

Regras de governança implementadas

O sistema de governança é composto pelas seguintes regras:

REG-01 — Validação de cálculos ambientais

Todo cálculo relacionado a CO2, energia ou pegada de carbono deve incluir comentário com a fonte e ano do fator utilizado. Caso a fonte não seja informada, o modelo deve alertar que o dado precisa de validação antes de uso em produção.

REG-02 — Proteção de credenciais

É proibido gerar ou manter credenciais, tokens ou strings de conexão em texto puro no código. Toda informação sensível deve ser externalizada para variáveis de ambiente, com alerta caso seja detectada exposição.

REG-03 — Testes unitários obrigatórios

Toda função de cálculo deve incluir pelo menos três testes: caso típico, caso de borda (zero) e caso inválido (negativo ou nulo).

REG-04 — Validação de dados de entrada

Funções que processam dados de sensores devem validar tipo, faixa de valores e nulidade antes de qualquer processamento, evitando aceitação silenciosa de dados inválidos.

REG-05 — Relatório de saída estruturado

Toda resposta deve incluir um resumo final contendo: riscos identificados, correções aplicadas e pontos que ainda exigem validação humana antes de deploy.

Embora as regras tenham sido criadas especificamente para a simulação, elas apresentam conformidade parcial com práticas recomendadas por frameworks e normas amplamente adotados, como COBIT, OWASP, NIST e ISO 14000, especialmente nos aspectos de segurança, rastreabilidade, qualidade de software e auditabilidade.

Objetivo da análise

A partir da comparação entre os dois cenários, o estudo busca:

- Avaliar o impacto das REGs na **redução de falhas lógicas e insegurança de código**
- Verificar a melhoria na **padronização das respostas**
- Analisar o nível de **controle efetivo obtido apenas via prompt engineering**
- Identificar limitações da governança baseada exclusivamente em instruções textuais

Resultado

Os resultados observados, bem como a análise, foram devidamente anexados no documento do github: [Analise.md](#).

Prompts utilizados:

Claude, preciso criar algumas regras de governança para uma IA que vai analisar e corrigir código de uma empresa fictícia. O foco deve ser segurança, documentação, testes, validação de dados e rastreabilidade das mudanças. As regras precisam ser objetivas e fáceis de auditar depois.
<https://github.com/igorgamma/Trab-governanca/tree/main>

vc poderia escrever de forma que eu possa adicionar no documento ja existente o que foi feito aqui?